

ZYROO CYBERSECURITY INTERNSHIP

Week 2 Findings Report: Vulnerability Scanning & Assessment

Intern Name: Safia Iftikhar

Program: Cybersecurity Internship (Batch 2026)

Target Environment: Metasploitable2 (Lab VM)

Scanning Tool: Nessus Essentials / OpenVAS

Date: September 2026

1. Executive Summary

This report documents the findings from the Week 2 vulnerability scanning and assessment project completed as part of the Zyroo Cybersecurity Internship. Building upon the lab environment established in Week 1 (*VM_{attacker}* and *VM_{target}*), this exercise focuses on deploying a professional vulnerability scanner, executing automated scans against a deliberately vulnerable target machine (Metasploitable2), analyzing discovered weaknesses, ranking risks, and providing actionable remediation recommendations.

The primary objective is to bridge theoretical reconnaissance concepts with structured vulnerability identification and risk reporting, standardizing the core workflows used in professional penetration testing and security assessments.

2. Lab Setup & Architecture

The lab environment was configured within Oracle VirtualBox, maintaining isolated network segments to safely test and exploit vulnerabilities without external exposure. Two primary virtual machines were established:

- **Attacker Machine (*Kali Linux*):** Used for running reconnaissance, managing tools, and executing vulnerability scans.
- **Target Machine (*Metasploitable2*):** A intentionally vulnerable Linux distribution configured with legacy services, weak credentials, and unpatched software flaws.

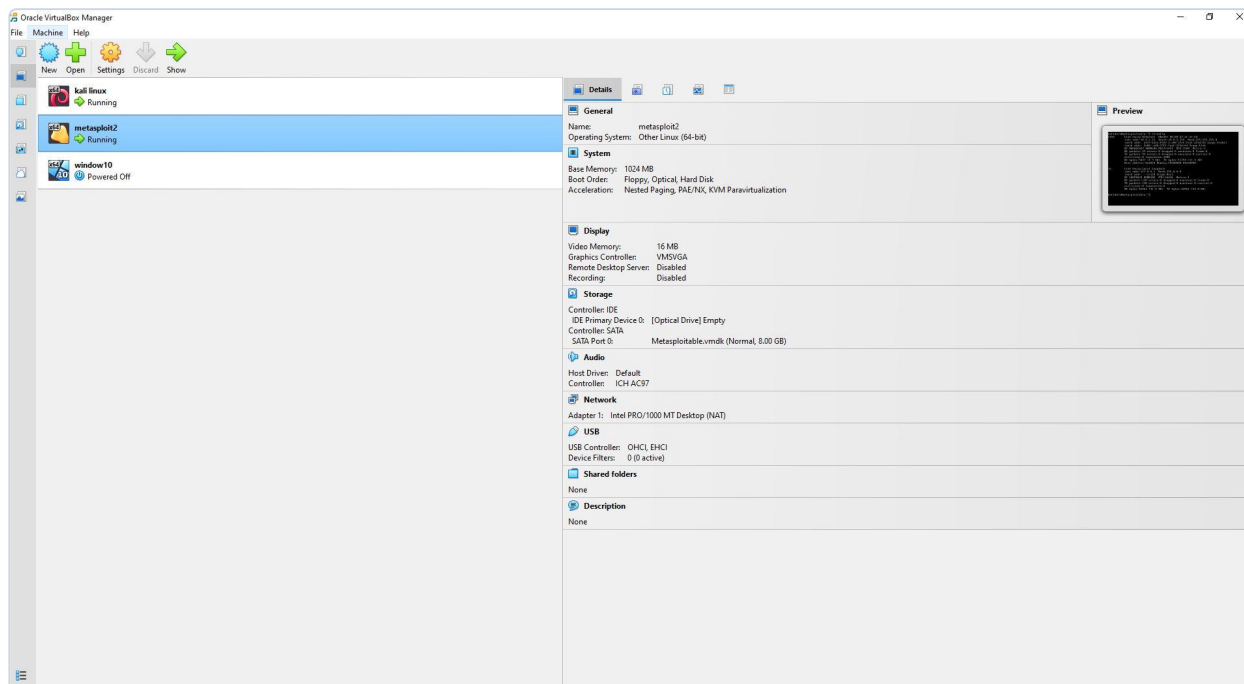


Figure 1: Oracle VirtualBox Manager displaying active Kali Linux and Metasploitable2 virtual machines.

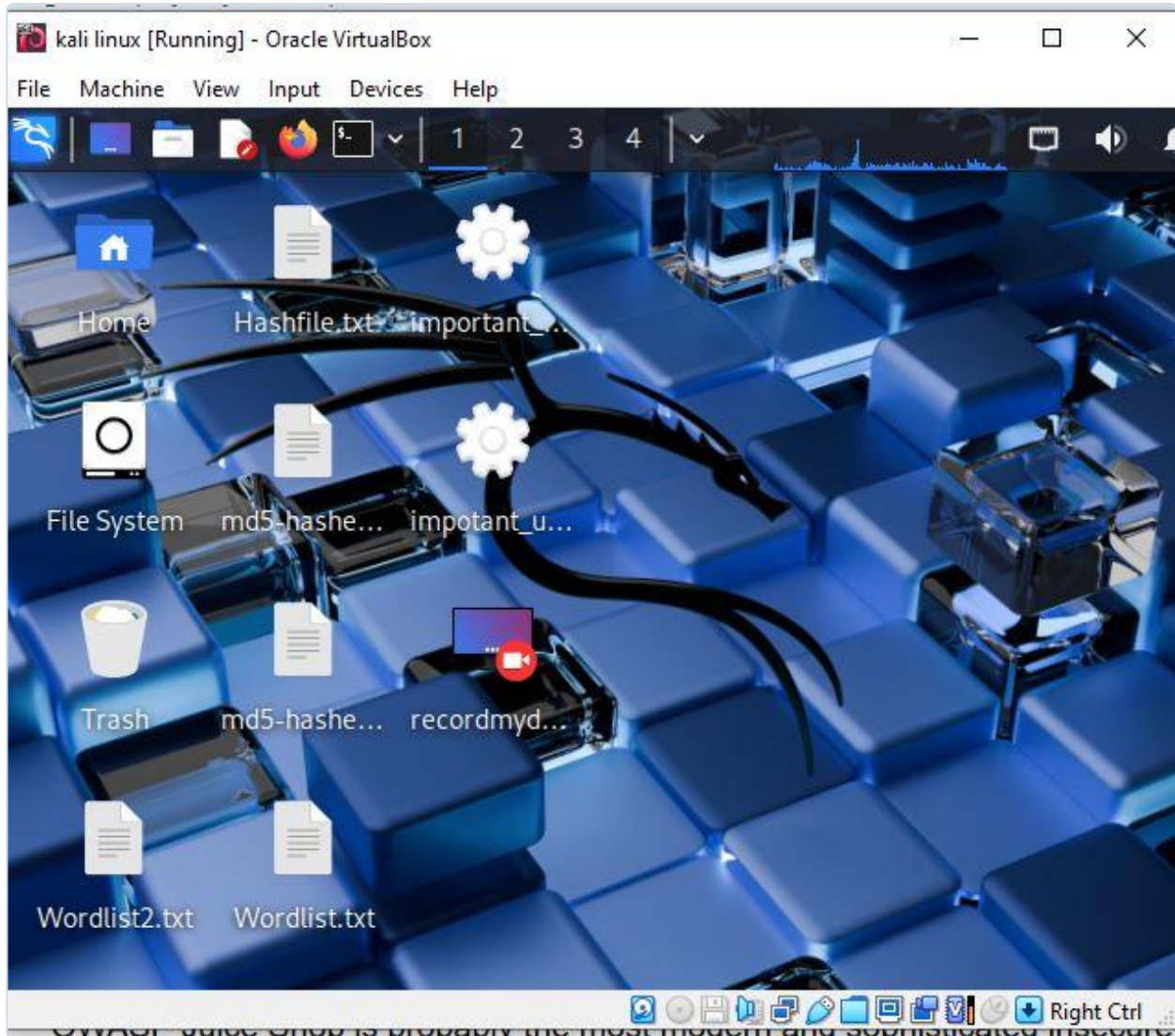
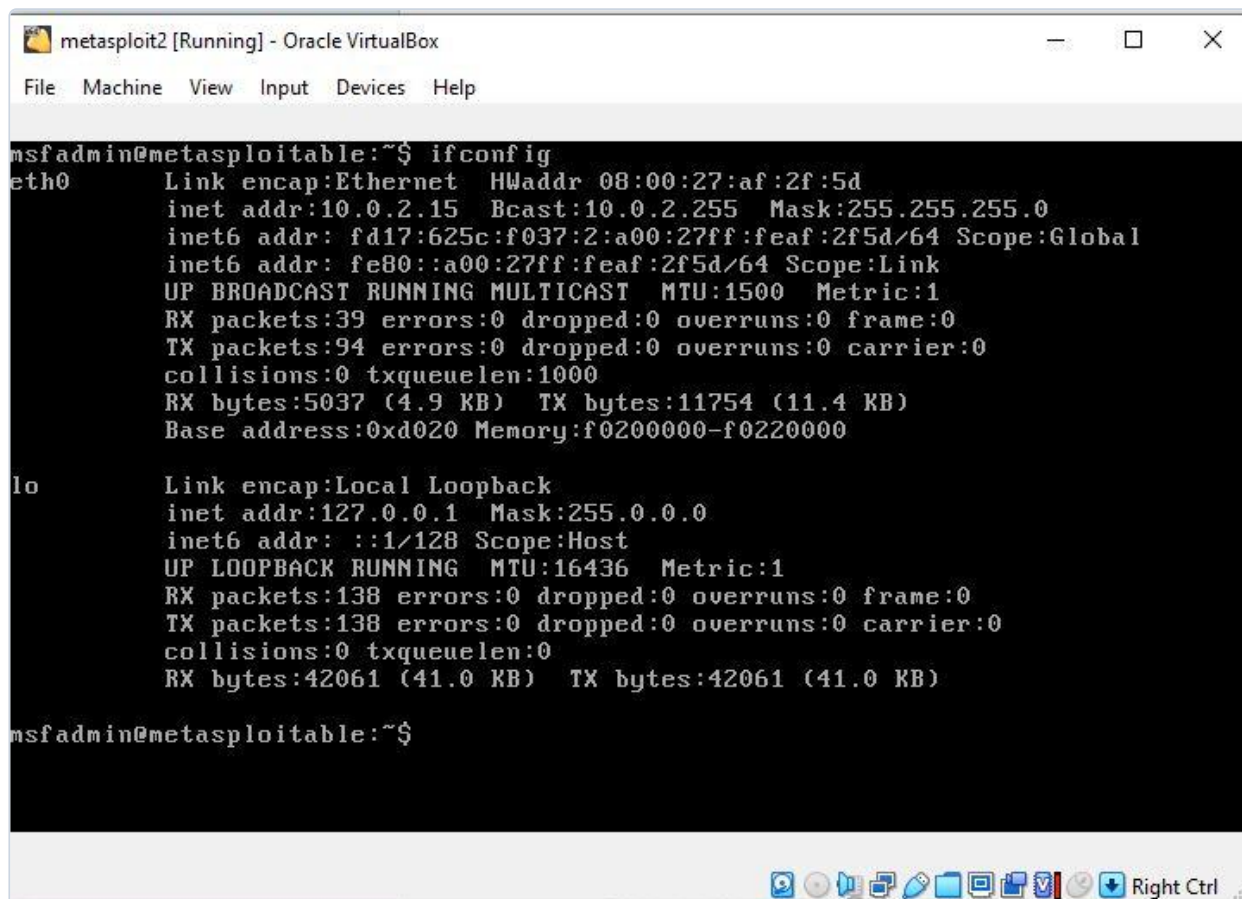


Figure 2: Kali Linux workstation desktop environment utilized for attack simulation and tool execution.

3. Network Configuration & Reachability Verification

Prior to initiating vulnerability scans, network interfaces were verified on both virtual machines to ensure proper routing and host reachability across the internal virtual switch (*NAT / Host-Only Network*).

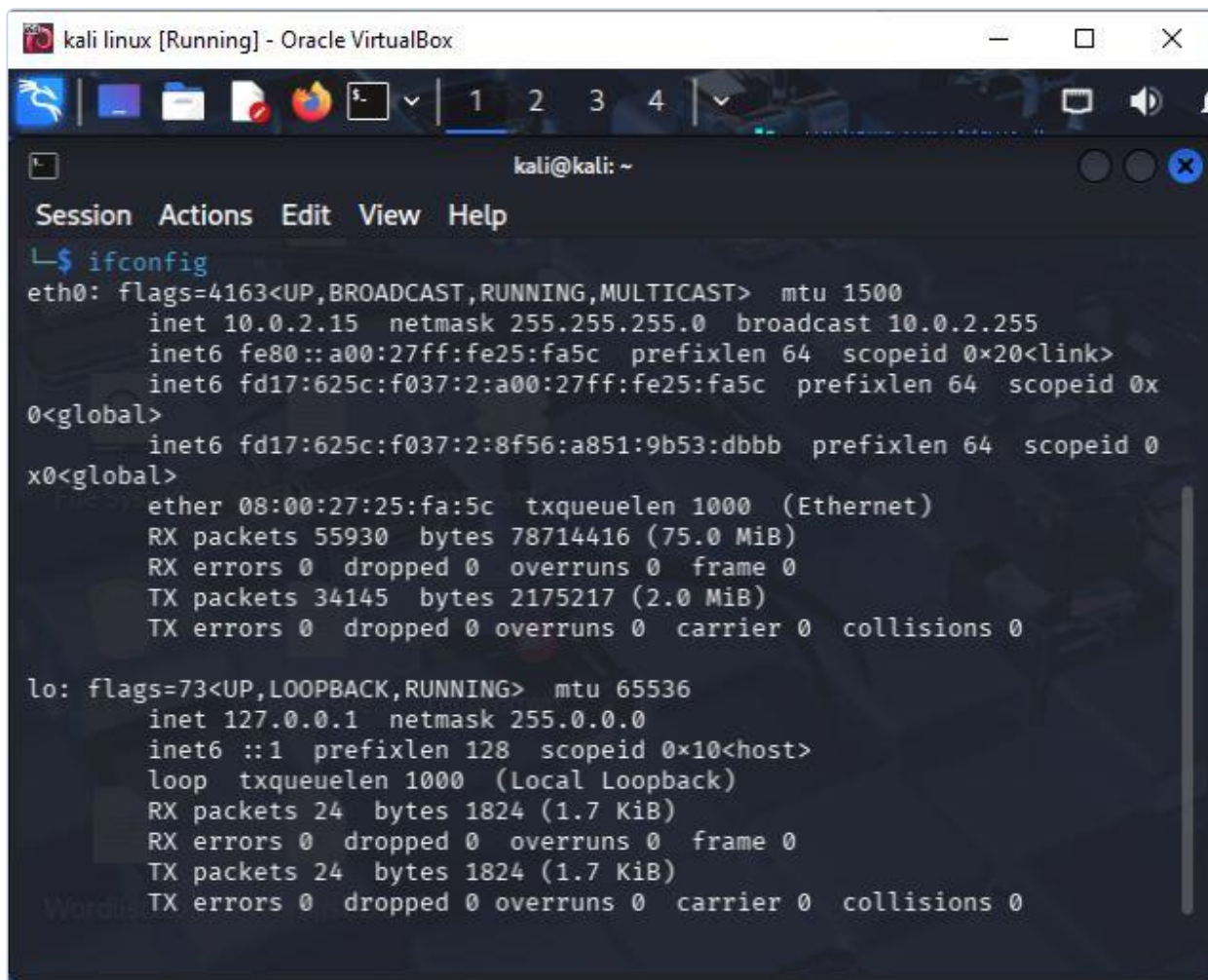


```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:af:2f:5d
          inet addr:10.0.2.15  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fd17:625c:f037:2:a00:27ff:feaf:2f5d/64  Scope:Global
          inet6 addr: fe80::a00:27ff:feaf:2f5d/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:39 errors:0 dropped:0 overruns:0 frame:0
          TX packets:94 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5037 (4.9 KB)  TX bytes:11754 (11.4 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:138 errors:0 dropped:0 overruns:0 frame:0
          TX packets:138 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:42061 (41.0 KB)  TX bytes:42061 (41.0 KB)

msfadmin@metasploitable:~$
```

Figure 3: Metasploitable2 target machine interface configuration (*eth0* IP: 10.0.2.15).



```
kali linux [Running] - Oracle VirtualBox
kali@kali: ~
Session Actions Edit View Help
L$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:fe25:fa5c prefixlen 64 scopeid 0<link>
    inet6 fd17:625c:f037:2:a00:27ff:fe25:fa5c prefixlen 64 scopeid 0x
0<global>
    inet6 fd17:625c:f037:2:8f56:a851:9b53:dbbb prefixlen 64 scopeid 0
x0<global>
    ether 08:00:27:25:fa:5c txqueuelen 1000 (Ethernet)
    RX packets 55930 bytes 78714416 (75.0 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 34145 bytes 2175217 (2.0 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 24 bytes 1824 (1.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 1824 (1.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 4: Kali Linux attacker machine interface configuration ensuring bidirectional connectivity.

4. Vulnerability Scanning Setup

A robust vulnerability scanner ([Nessus Essentials](#)) was installed on the host/Kali environment via its Debian package distribution ([Nessus-10.12.4-debian10_amd64.deb](#)). The scanner daemon was initialized, allowing deep inspection of open ports, banner grabbing, and CVE matching against the target scope.

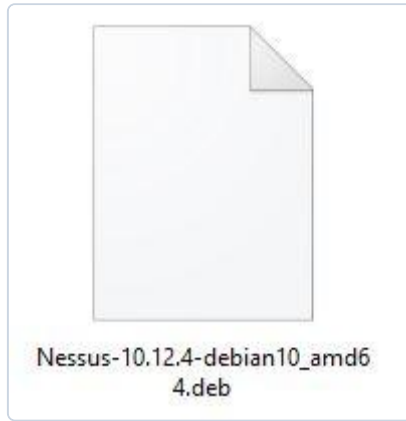


Figure 5: Nessus vulnerability scanner installation package (.deb format).

5. Vulnerability Analysis & Risk Ranking

The vulnerability scan against Metasploitable2 revealed numerous critical and high-severity findings across multiple legacy network services. Below is the ranked summary of the top 5 distinct vulnerabilities identified during the assessment:

Risk Rank	Vulnerability Name	Port / Service	Severity	CVE Reference
1	vsftpd 2.3.4 Backdoor Command Execution	Port 21 / FTP	CRITICAL	CVE-2011-2523
2	Samba 3.0.20 Username Map Script Execution	Port 139/445 / SMB	CRITICAL	CVE-2007-2447
3	Apache Tomcat / Coyote JSP/HTML Engine Misconfiguration	Port 8180 / HTTP	HIGH	CVE-2009-3843
4	DistCC Daemon Command Execution	Port 3632 / DistCC	HIGH	CVE-2004-2687
5	Unauthenticated MySQL Server Access	Port 3306 / MySQL	MEDIUM	N/A (Config Flaw)

6. Detailed Findings & Remediation Recommendations

1. vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Description: A malicious backdoor was maliciously introduced into the vsftpd 2.3.4 archive on the master distribution site. When a smiley face character (:) is appended to the username during login, the software opens a shell on port 6200.

Remediation: Immediately upgrade the FTP server to a patched, vendor-supported version (vsftpd 3.x or higher) or disable FTP in favor of secure alternatives such as SFTP.

2. Samba 3.0.20 Username Map Script (CVE-2007-2447)

Description: Samba versions 3.0.0 through 3.0.25rc3 contain a command injection vulnerability in the username map script parameter, allowing remote attackers to execute arbitrary shell commands via specially crafted usernames containing shell metacharacters.

Remediation: Update Samba to version 3.0.25rc3 or later, or remove the *username map script* line from the *smb.conf* configuration file.

3. Unauthenticated MySQL Database Access

Description: The MySQL service allows remote connections with default credentials (root / blank password), enabling unauthorized database enumeration, data exfiltration, and potential SQL injection abuse.

Remediation: Enforce strong root passwords, disable remote root login by default (*bind-address = 127.0.0.1*), and run *mysql_secure_installation*.

7. Conclusion

Week 2 of the Zyroo Cybersecurity Internship successfully demonstrated the end-to-end vulnerability assessment lifecycle. By configuring Nessus/OpenVAS, executing active scans against Metasploitable2, and analyzing critical CVEs, essential foundational skills in vulnerability management and technical reporting were mastered. All deliverables and verification checkpoints have been successfully met and pushed to the GitHub repository.